

HiveForce Labs

THREAT ADVISORY

VULNERABILITY REPORT

The Vulnerability Discovered in the Cacti Open-Source RRD tool

Date of Publication

January 16, 2023

Admiralty Code

A1

TA Number

TA2023024

Summary

First Seen: December 2022

Affected Product: Cacti

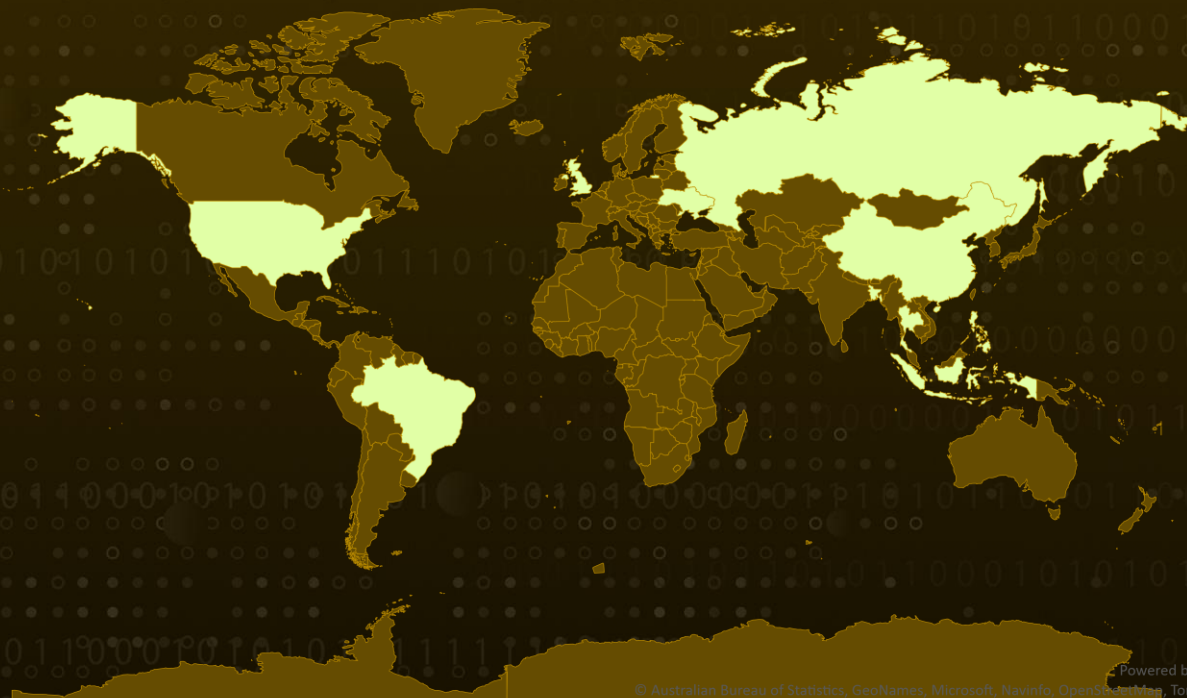
Vulnerable Regions: Brazil, Indonesia, United States, China, Bangladesh, Russia, Ukraine, Philippines, Thailand, United Kingdom

Impact: The vulnerability allows for command injection and remote code execution

⚙ CVEs

CVE	NAME	PATCH
CVE-2022-46169	Remote command execution in Cacti	✓

🌐 Vulnerable Regions



Vulnerability Details

#1

A high-severity vulnerability named CVE-2022-46169 has been found in Cacti, a free, open-source, web-based network monitoring and graphing tool designed as a front-end application for the open-source data logging tool RRDtool. The vulnerability allows for command injection and remote code execution and was first detailed in a security advisory by Cacti in December 2022.

#2

The vulnerability was not widely noticed until January 2023, when it was reported that it was being actively exploited in the wild to download and install malware. Most of the affected Cacti servers are running outdated versions, with a large number located in Brazil, Indonesia, and the United States. The vulnerability can be exploited through a specific HTTP query and allows an attacker to bypass authentication, making it a valuable target for attackers.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-46169	Cacti: 1.2.0 - 1.2.22	cpe:2.3:a:the_cacti_group:cacti:1.2.22:*:*:*:*:*	CWE-285

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Details' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0005</u> Defense Evasion	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0043</u> Reconnaissance
<u>TA0042</u> Resource Development	<u>TA0011</u> Command and Control	<u>T1553</u> Subvert Trust Controls	<u>T1553.005</u> Mark-of-the-Web Bypass
<u>T1216</u> System Script Proxy Execution	<u>T1071</u> Application Layer Protocol	<u>T1071.001</u> Web Protocol	<u>T1590</u> Gather Victim Network Information
<u>T1592</u> Gather Victim Host Information	<u>T1203</u> Exploitation for Client Execution	<u>T1588.005</u> Exploits	<u>T1509</u> Command and Scripting Interpreter
<u>T1588.006</u> Vulnerabilities	<u>T1588</u> Obtain Capabilities		

Patch Details

Upgrade to the latest version of Cacti (v1.2.23 and v1.3.0)

Links:

<https://github.com/Cacti/cacti/security/advisories/GHSA-6p93-p743-35gf>

<https://github.com/Cacti/cacti/commit/b43f13ae7f1e6bfe4e8e56a80a7cd867cf2db52b>

<https://github.com/Cacti/cacti/commit/a8d59e8fa5f0054aa9c6981b1cbe30ef0e2a0ec9>

<https://github.com/Cacti/cacti/commit/7f0e16312dd5ce20f93744ef8b9c3b0f1ece2216>

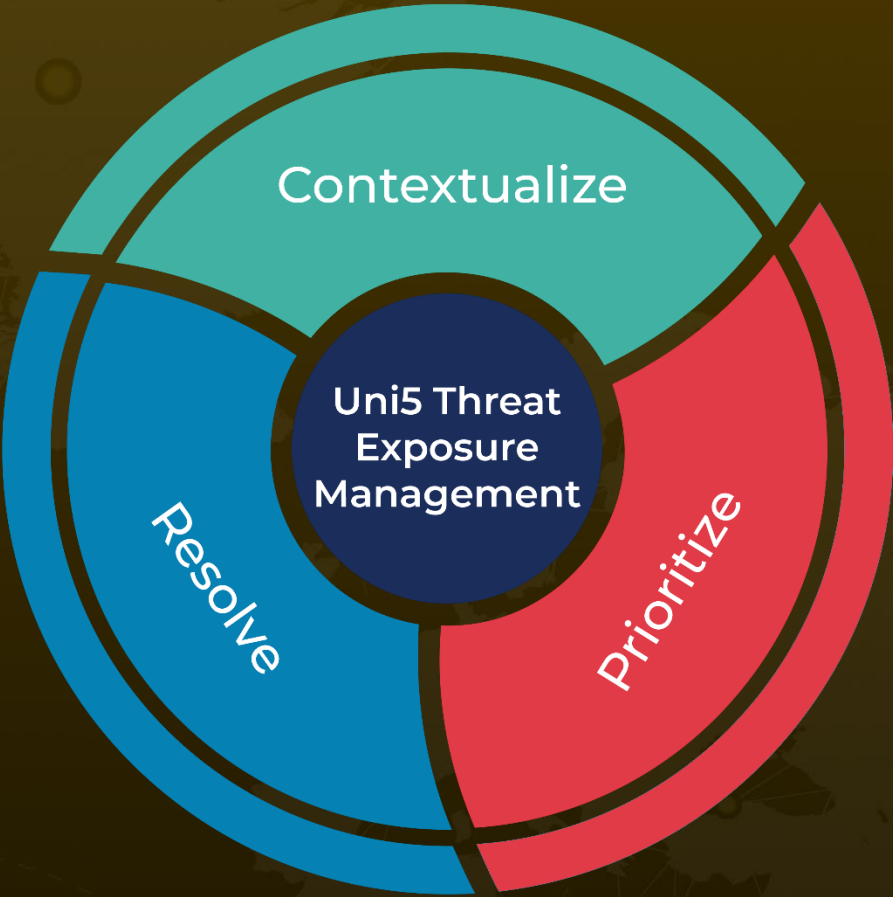
References

<https://censys.io/cve-2022-46169-cacti/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
January 16, 2023 • 12:22AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com